

INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha: 16/07/2025
- Entorno : Windows 2007

○ IP-> 192.168.88.147

ÍNDICE

- 1. OBJETIVO Y ALCANCE
- 2. SUMARIO EJECUTIVO
- 3. CLASIFICACIÓN DE VULNERABILIDADES
- 4. VULNERABILIDADES DETECTADAS
- 5. RECOMENDACIONES GENERALES
- 6.- EVIDENCIAS
- 7.- CONCLUSIÓN

OBJETIVO Y ALCANCE

- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows 7** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- Tras el análisis del sistema Windows 7, se han detectado vulnerabilidades de nivel **crítico, alto, medio y bajo**. Las más críticas permiten la ejecución remota de código, mientras que otras permiten la enumeración de usuarios o la exposición de información sensible.
- El sistema presenta una configuración obsoleta y servicios innecesarios expuestos, lo que incrementa la superficie de ataque.
- Recomendamos tomar medidas correctivas inmediatas sobre los servicios de red activos y establecer políticas más restrictivas en la red para reducir el riesgo global.

CLASIFICACIÓN DE VULNERABILIDADES

- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.

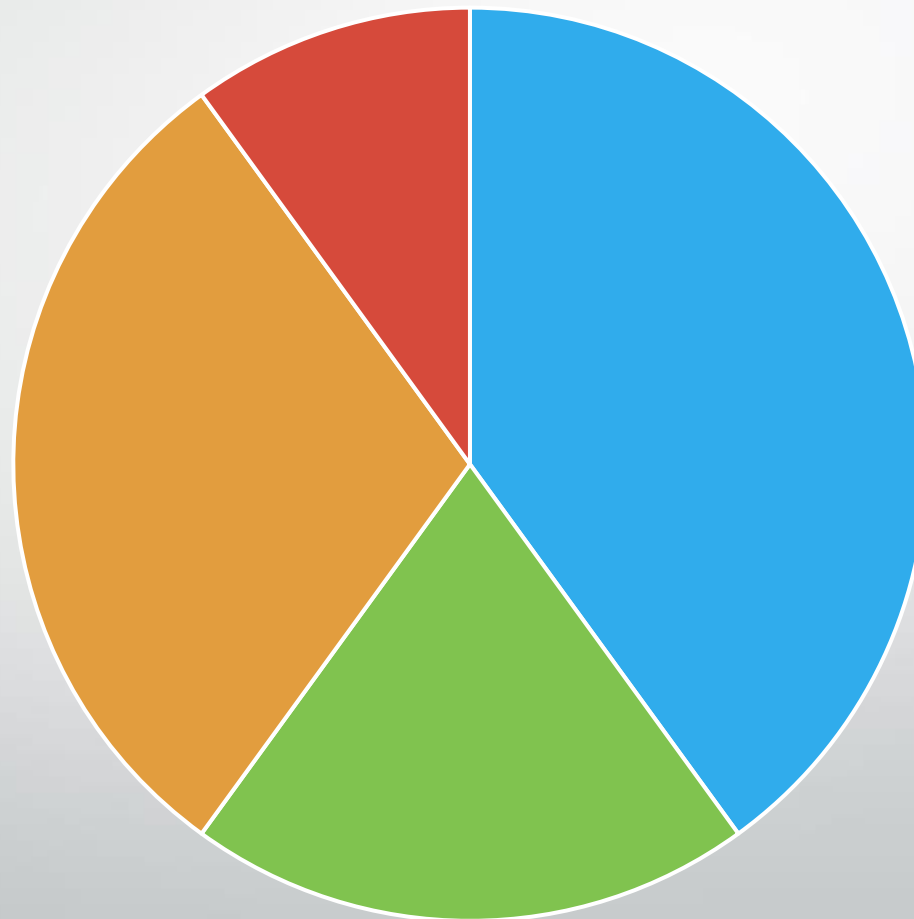


TABLA DE VULNERABILIDADES

Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	445	SMB	Este servicio puede ser vulnerable a ejecución remota de código.	CVE-2009-3103	Aplicar parches de seguridad. Deshabilitar SMBv1 si está activo. Restringir acceso por firewall.
Alto	139	NetBIOS	Permite enumeración de recursos compartidos, usuarios y nombres de máquina. Puede ser útil para ataques dirigidos en red interna.	-CVE-2017-0144 -CVE-2020-0796	Deshabilitar NetBIOS si no se utiliza. Filtrar el tráfico por firewall.
Medio	135,49152 - 49157	MSRPC	Múltiples servicios RPC expuestos permiten enumeración del sistema y podrían facilitar ataques como PrintNightmare si no se aplican parches.	CVE-2021-1675	Limitar exposición por red, segmentar servicios, aplicar principio de mínimo privilegio.
Bajo		Sistema operativo	El sistema operativo detectado (Windows 7) ha alcanzado fin de soporte por parte de Microsoft, lo que lo deja expuesto a vulnerabilidades no parcheadas.		Migrar a un sistema con soporte activo, como Windows 10 o 11.

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 445 ■ Puerto 135, 49152-49157 ■ Puerto 139 ■ Sistema Operativo

RECOMENDACIONES

- Se recomiendan medidas correctivas a nivel de servicios, usuarios y red, tales como:
 - Deshabilitar SMBv1 y puertos innecesarios.
 - Aplicar políticas de contraseñas robustas.
 - Limitar accesos administrativos por red.
 - Aplicar segmentación de red y filtrado por firewall.
 - Mantener el sistema actualizado y con parches de seguridad.

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

EVIDENCIA N° 1 – Servicio SMB activo

- **Puerto:** 445
- **Nivel de riesgo:** Crítico
- **Servicio:** microsoft-ds
- **Recomendación:**
 - Aplicar parches de seguridad. Deshabilitar SMBv1 si está activo. Restringir acceso por firewall.
- **Descripción:**
 - Se observa el puerto 445 abierto con el servicio microsoft-ds activo en el host . Este servicio corresponde al protocolo SMB, que en sistemas Windows 7 sin parches puede ser vulnerable a ejecución remota de código (CVE-2009-3103). Esta configuración representa una amenaza crítica si no se restringe o actualiza.

```
PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:0A:64:39 (VMware)

Host script results:
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2:0:2
|     2:1:0
```

```
Anonymous login successful
```

Sharename	Type	Comment
Reconnecting with SMB1 for workgroup listing.		
do_connect: Connection to 192.168.88.147 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)		
Unable to connect with SMB1 -- no workgroup available		

EVIDENCIA N° 2 – Servicio NetBIOS expuesto

- Puerto: 139
- Nivel de riesgo: Alto
- Servicio: netbios-ssn
- Recomendación:
 - Deshabilitar NetBIOS si no se utiliza. Filtrar el tráfico por firewall.
- Descripción:
 - Se detecta el puerto 139 abierto, correspondiente al servicio NetBIOS. Aunque es habitual en sistemas Windows antiguos, su exposición permite enumeración de usuarios, recursos compartidos y nombres de host, lo que facilita el reconocimiento por parte de un atacante.

```
===== ( Enumerating Workgroup/Domain on 192.168.88.147 ) =====
[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.88.147 ) =====

Looking up status of 192.168.88.147
THUNDERCATS <20> - M <ACTIVE> File Server Service
THUNDERCATS <00> - M <ACTIVE> Workstation Service
WORKGROUP <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
WORKGROUP <1e> - <GROUP> M <ACTIVE> Browser Service Elections
WORKGROUP <1d> - M <ACTIVE> Master Browser
.. _MSBROWSE_ <01> - <GROUP> M <ACTIVE> Master Browser

MAC Address = 00-0C-29-0A-64-39

===== ( Session Check on 192.168.88.147 ) =====

[+] Server 192.168.88.147 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.88.147 ) =====

do_cmd: Could not initialise lsarpc. Error was NT_STATUS_ACCESS_DENIED
[+] Can't determine if host is part of domain or part of a workgroup
```

EVIDENCIA N° 3 – Servicios RPC múltiples expuestos

- **Puertos:** 135, 49152–49157
- **Nivel de riesgo:** Medio
- **Servicio:** msrpc
- **Recomendación:**
 - Limitar exposición por red, segmentar servicios, aplicar principio de mínimo privilegio.
- **Descripción:**
 - El escaneo detecta múltiples puertos abiertos correspondientes a Microsoft Windows RPC (135 y rango 49152–49157). Esta configuración puede permitir la enumeración del sistema y sugiere exposición innecesaria a ataques de lateralización como Print Spooler (CVE-2021-1675).

```
192.168.88.147:135    - 0b6edbf8-4a24-4fc6-8a23-942b1eca65d1 v1.0 LRPC (spoolss) [Spooler function endpoint]
192.168.88.147:135    - ae33069b-a2a8-46ee-a235-ddfd339be281 v1.0 LRPC (spoolss) [Spooler base remote object endpoint]
192.168.88.147:135    - 4a452661-8290-4b36-8f8e-7f4093a94978 v1.0 LRPC (spoolss) [Spooler function endpoint]
```

EVIDENCIA N° 4 – Sistema operativo sin soporte

- **OS detectado:** Windows 7
- **Nivel de riesgo:** Bajo
- **Recomendación:**
 - Migrar a un sistema con soporte activo, como Windows 10 o 11.
- **Descripción:**
 - El sistema operativo identificado es Windows 7. Este sistema se encuentra fuera del soporte oficial de Microsoft desde enero de 2020, por lo que ya no recibe parches de seguridad, lo que aumenta el riesgo de explotación por vulnerabilidades conocidas.

Running: Microsoft Windows 2008|7|Vista|8.1

OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista

OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1

CONCLUSIÓN

- El análisis de seguridad realizado sobre el sistema **Windows 7** ha permitido identificar varios servicios de red expuestos que, en su conjunto, incrementan la superficie de ataque del entorno auditado.
- La detección del servicio **SMBv2 activo en el puerto 445**, combinado con la presencia de múltiples puertos asociados a **MSRPC**, la exposición de **NetBIOS (puerto 139)** y la utilización de un **sistema operativo sin soporte oficial**, representan un riesgo considerable frente a ataques internos o automatizados.
- Se recomienda proceder a la **actualización del sistema operativo a una versión con soporte vigente**, limitar la exposición innecesaria de servicios mediante segmentación y firewall, y establecer un plan de mantenimiento y revisión periódica de la postura de seguridad del entorno.

INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha : 16/07/2025
- Entorno : Windows 2008
 - IP-> 192.168.88.139

OBJETIVO Y ALCANCE

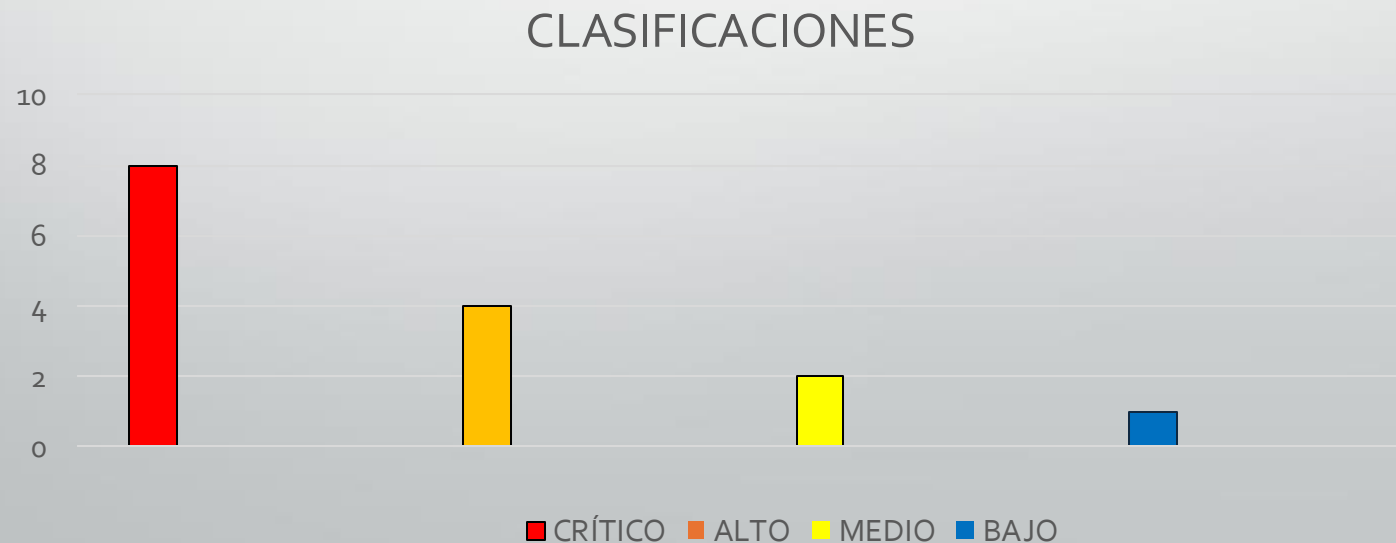
- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows Server 2008** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- Tras el análisis del sistema Windows Server 2008, se han detectado vulnerabilidades de nivel **crítico, alto, medio y bajo**. Se han identificado vulnerabilidades críticas como ejecución remota de código, exposición innecesaria de servicios, y uso de un sistema operativo sin soporte. Estos factores aumentan el riesgo global del entorno evaluado.
- Recomendamos tomar medidas correctivas inmediatas sobre los servicios de red activos y establecer políticas más restrictivas en la red para reducir el riesgo global.

CLASIFICACIÓN DE VULNERABILIDADES

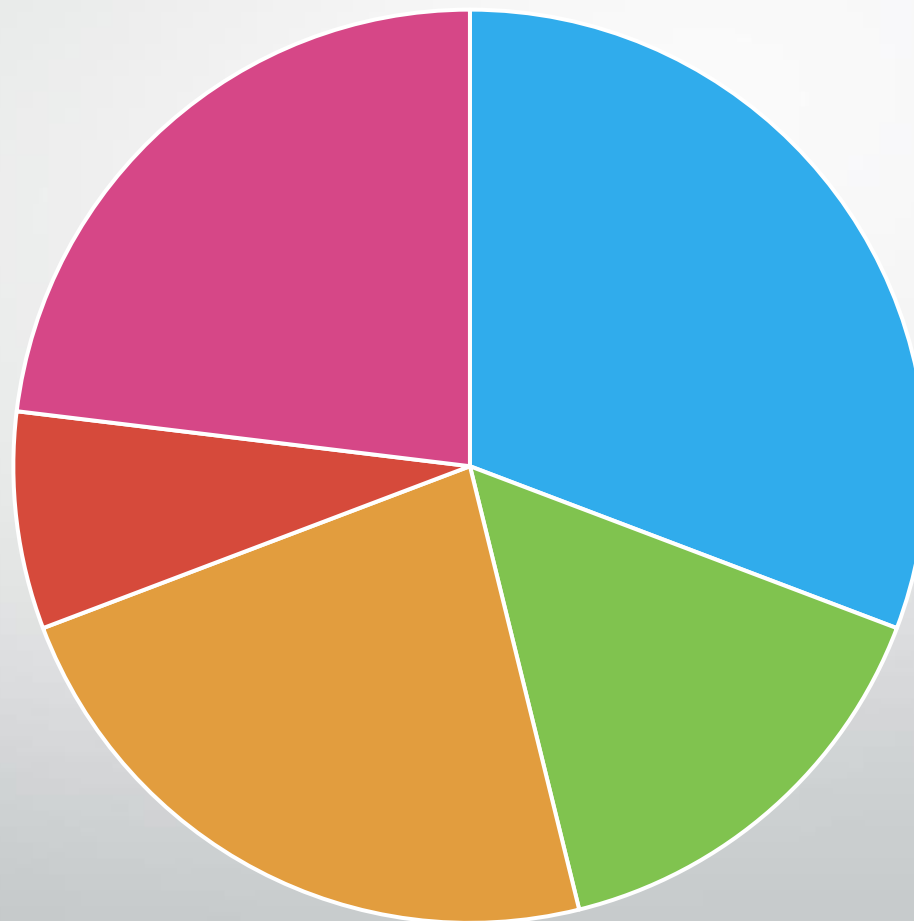
- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.



Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	445	SMBv1	El protocolo SMBv1 es obsoleto y vulnerable a múltiples ataques, como EternalBlue, que permite la ejecución remota de código sin autenticación.	CVE-2017-0143	Deshabilitar SMBv1, aplicar parches, restringir acceso por firewall, migrar a SMBv3 si es posible
Alto	3389	RDP	Servicio expuesto sin protección (sin NLA), susceptible a fuerza bruta y recolección de credenciales.	CVE-2019-0708 (<i>BlueKeep</i>)	-Habilitar NLA, restringir por IP, MFA y actualización crítica del sistema.
Medio	135, 1688, 49152-49157	MSRPC	-Permite enumeración de red y explotación de servicios Windows como Print Spooler si no está parcheado.	CVE-2021-1675 (<i>PrintNightmare</i>)	-Aplicar parches, segmentar red, mínimo privilegio.
Bajo	139	NetBIOS	Permite la enumeración de usuarios y recursos compartidos desde red local. Útil para reconocimiento en ataques internos.	-	Deshabilitar NetBIOS si no se usa. Filtrar tráfico.
Bajo	-	Sistema Operativo	Uso de sistema sin soporte oficial (Windows Server 2008 R2), lo que implica ausencia de parches frente a nuevas amenazas.	— (<i>riesgo estructural</i>)	Migrar a un sistema con soporte activo (ej. Windows Server 2022).

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 445 ■ Puerto 135, 4915 ■ Puerto 139 ■ Sistema Operativo ■ Puerto 3389

RECOMENDACIONES

- Se recomiendan medidas correctivas a nivel de servicios, usuarios y red, tales como:
 - Migrar a sistema operativo con soporte oficial.
 - Deshabilitar NetBIOS si no es necesario.
 - Restringir acceso a RDP y MSRPC.
 - Deshabilitar puertos no utilizados.

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

EVIDENCIA N° 1 – Servicio SMBv1 activo

- Puerto: 445
- Nivel de riesgo: Crítico
- Servicio: microsoft-ds
- Recomendación:
 - Deshabilitar SMBv1, aplicar parches, restringir acceso por firewall, migrar a SMBv3 si es posible
- Descripción:
 - El escaneo muestra el puerto 445 abierto con el servicio microsoft-ds activo, que corresponde a **SMBv1**, como se ha verificado en el análisis de protocolos (smb-protocols). Este protocolo es inseguro y ha sido afectado por múltiples vulnerabilidades críticas, entre ellas **EternalBlue** (CVE-2017-0143), que permite ejecución remota de código sin autenticación en versiones sin parchear. Esta evidencia confirma la exposición de este servicio en el sistema Windows 8, lo que representa un riesgo grave de seguridad.

```
Nmap scan report for 192.168.88.139
Host is up (0.00014s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:33:A8:49 (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs:  CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|         servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|     https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_

Nmap done: 1 IP address (1 host up) scanned in 15.24 seconds
```

EVIDENCIA N° 2 – RDP expuesto

- **Puerto:** 3389
- **Nivel de riesgo:** Alto
- **Servicio:** ms-wbt-server (RDP)
- **Recomendación:**
 - Habilitar NLA, restringir por IP, MFA y actualización crítica del sistema.
- **Descripción:**
 - El escaneo detecta el puerto 3389 abierto, correspondiente al servicio de Escritorio Remoto (RDP). Si este servicio no está protegido con NLA (Network Level Authentication), puede ser vulnerable a ataques como BlueKeep (CVE-2019-0708). Esta exposición incrementa el riesgo de acceso remoto no autorizado al sistema.

```
PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server
| rdp-vuln-ms12-020:
|   VULNERABLE:
|   MS12-020 Remote Desktop Protocol Denial Of Service Vulnerability
|   State: VULNERABLE
|   IDs: CVE:CVE-2012-0152
|   Risk factor: Medium CVSSv2: 4.3 (MEDIUM) (AV:N/AC:M/Au:N/C:N/I:N/A:P)
|   Remote Desktop Protocol vulnerability that could allow remote attackers to cause a denial of service.
|
|   Disclosure date: 2012-03-13
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-0152
|   http://technet.microsoft.com/en-us/security/bulletin/ms12-020
|
|   MS12-020 Remote Desktop Protocol Remote Code Execution Vulnerability
|   State: VULNERABLE
|   IDs: CVE:CVE-2012-0002
|   Risk factor: High CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:C/I:C/A:C)
|   Remote Desktop Protocol vulnerability that could allow remote attackers to execute arbitrary code on the targeted system.
|
|   Disclosure date: 2012-03-13
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-0002
|   http://technet.microsoft.com/en-us/security/bulletin/ms12-020
```


EVIDENCIA N° 3 – Servicio MSRPC expuesto

- **Puerto:** 135
- **Nivel de riesgo:** Medio
- **Servicio:** msrpc
- **Recomendación:**
 - Aplicar parches, segmentar red, mínimo privilegio.
- **Descripción:**
 - El puerto 135 está abierto con el servicio MSRPC activo. Este puerto permite llamadas a procedimientos remotos y puede servir como puerta de entrada para ataques como PrintNightmare (CVE-2021-1675) si no se encuentra correctamente parcheado.

```
===== ( Target Information ) =====
Target ..... 192.168.88.139
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.88.139 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.88.139 ) =====

Looking up status of 192.168.88.139
CPHE          <00> -      M <ACTIVE>  Workstation Service
WORKGROUP     <00> - <GROUP> M <ACTIVE>  Domain/Workgroup Name
CPHE          <20> -      M <ACTIVE>  File Server Service

MAC Address = 00-0C-29-33-A8-49

===== ( Session Check on 192.168.88.139 ) =====

[+] Server 192.168.88.139 allows sessions using username '', password ''
```

EVIDENCIA N° 4 – NetBIOS expuesto

- **Puerto:** 139
- **Nivel de riesgo:** Bajo
- **Servicio:** netbios-ssn
- **Recomendación:**
 - Deshabilitar NetBIOS si no se usa. Filtrar tráfico.
- **Descripción:**
 - El puerto 139 está abierto con el servicio NetBIOS activo. Este servicio, aunque común en sistemas antiguos, permite la enumeración de nombres de equipos, usuarios y recursos compartidos desde la red local. Si no se encuentra filtrado o restringido, puede ser aprovechado por un atacante en fase de reconocimiento.

```
Doing NBT name scan for addresses from 192.168.88.0/24
```

IP address	NetBIOS Name	Server	User	MAC address
192.168.88.128	<unknown>		<unknown>	
192.168.88.139	CPHE	<server>	<unknown>	00:0c:29:33:a8:49

EVIDENCIA N° 5 – Sistema Operativo sin soporte

- **Sistema detectado:** Windows 8
- **Nivel de riesgo:** Bajo
- **Recomendación:**
 - Migrar a un sistema con soporte activo (ej. Windows Server 2022).
- **Descripción:**
 - El sistema operativo detectado en el host auditado es **Windows 8**, el cual **finalizó su soporte extendido por parte de Microsoft en enero de 2023**. Esto significa que ya no recibe actualizaciones de seguridad ni parches críticos, lo que deja al sistema expuesto frente a nuevas vulnerabilidades. Aunque esta condición no representa una vulnerabilidad técnica inmediata, **constituye una debilidad estructural grave a medio y largo plazo**.

```
Host script results:
| smb-os-discovery:
|   OS: Windows Server (R) 2008 Standard 6001 Service Pack 1 (Windows Server (R) 2008 Standard 6.0)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::sp1
|   Computer name: cphe
|   NetBIOS computer name: CPHE\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2025-07-18T12:22:00-05:00
```

CONCLUSIÓN

- El sistema evaluado presenta vulnerabilidades de riesgo crítico como la ejecución remota de código mediante **SMBv1**, un protocolo obsoleto aún habilitado en el sistema, y conocido por ser explotable mediante ataques como **EternalBlue (CVE-2017-0144)**. Esta exposición, combinada con servicios innecesarios como RDP sin restricciones, NetBIOS y un sistema operativo sin soporte oficial, amplía significativamente la superficie de ataque., combinadas con exposiciones innecesarias de servicios como RDP y NetBIOS, y la utilización de un sistema sin soporte oficial. Esta combinación amplía la superficie de ataque y expone a la organización a posibles incidentes de seguridad.
- Se recomienda priorizar la corrección de estos problemas, actualizar el sistema operativo, aplicar segmentación de red y realizar auditorías periódicas para asegurar la evolución continua de la postura de seguridad.

INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha : 16/09/2025
- Entorno: Windows 10

OBJETIVO Y ALCANCE

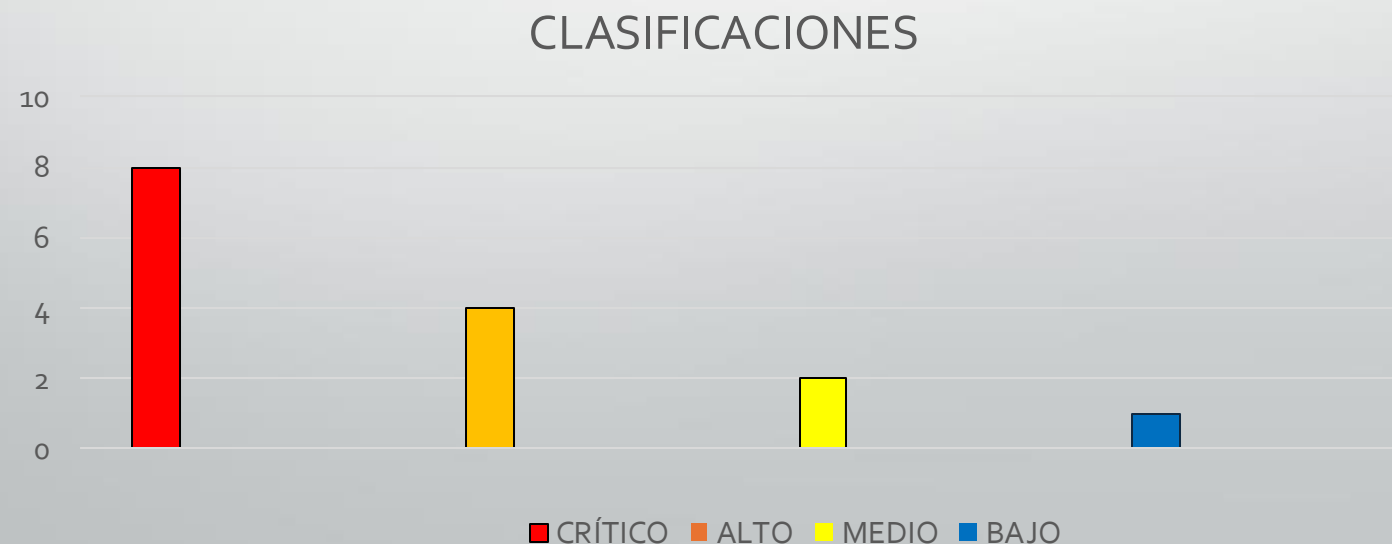
- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows 10** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- Durante la auditoría de seguridad realizada sobre el sistema operativo **Windows 10**, se identificaron múltiples servicios expuestos con distintos niveles de riesgo. Entre las vulnerabilidades de mayor criticidad se encuentran:
- Un **servidor FTP (FileZilla beta)** accesible sin cifrado.
- El servicio **SMBv2 activo en el puerto 445**, asociado a vulnerabilidades históricas críticas.
- El **protocolo RDP expuesto sin medidas adicionales de protección** como NLA.
- Un servicio **VNC accesible públicamente**, potencialmente sin cifrado ni autenticación fuerte.
- Además, se detectaron otros servicios de riesgo medio y bajo como **puertos MSRPC expuestos, NetBIOS habilitado**, y un **servidor web IIS** sin información clara sobre su configuración de seguridad.
- La presencia simultánea de estos servicios abiertos incrementa la superficie de ataque del sistema y puede ser aprovechada por un atacante tanto en redes internas como externas.

CLASIFICACIÓN DE VULNERABILIDADES

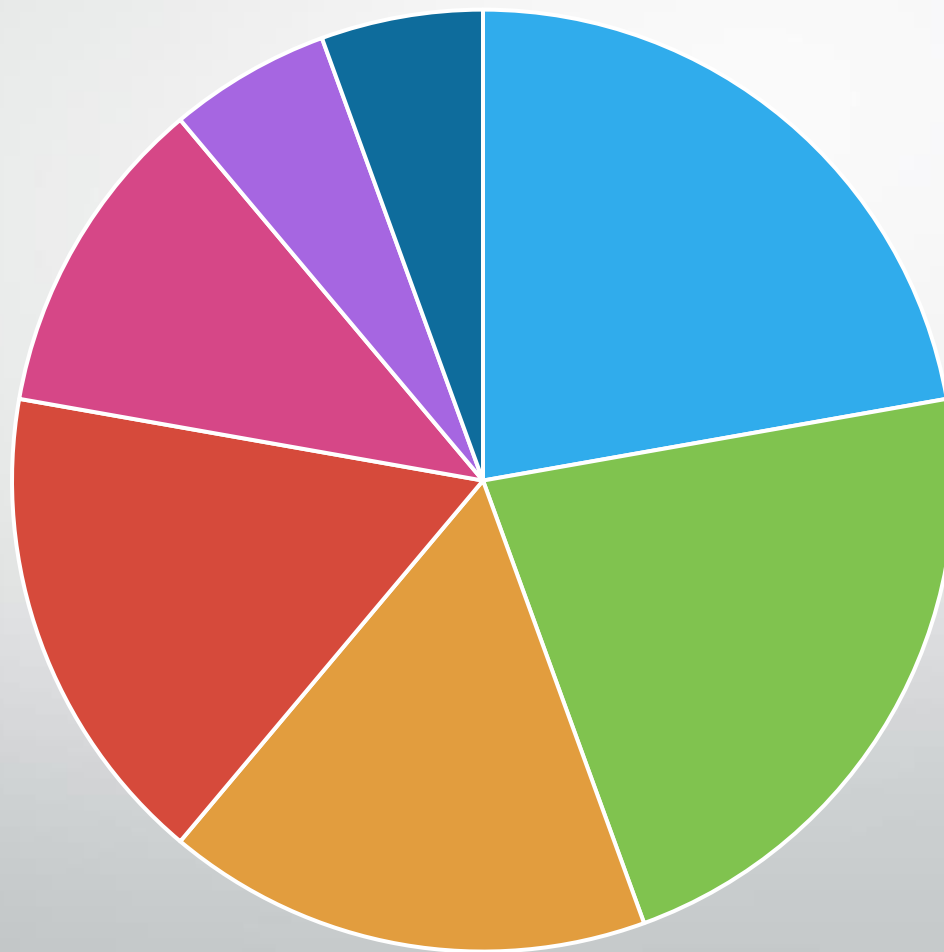
- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.



Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	445	SMBv1	El protocolo SMBv1 está habilitado. Esto permite ataques como EternalBlue (ejecución remota de código), propagación de ransomware y otros exploits críticos	CVE-2017-0144	Deshabilitar SMBv1, aplicar el parche de seguridad MS17-010, actualizar el sistema y restringir el acceso a SMB desde redes externas.
Crítico	21	FTP(FileZilla)	FileZilla 0.9.60 beta permite conexiones sin cifrado y puede aceptar acceso anónimo o sin control. Vulnerable a exposición o acceso no autorizado.	CVE-2020-0796, CVE-2017-0144	Aplicar parches, deshabilitar SMBv1, restringir por firewall.
Alto	3389	RDP	Puerto RDP expuesto públicamente sin verificación adicional. Riesgo alto de fuerza bruta o explotación (ej: BlueKeep).	CVE-2019-0708	Habilitar NLA, restringir por IP, aplicar MFA y parches.
Alto	5800/5900	VNC (TightVNC)	VNC sin cifrado o puede exponer el escritorio remoto a interceptación o acceso remoto no autorizado.	CVE-2019-15681	Habilitar autenticación fuerte, cifrado o restringir uso de VNC.
Medio	135, 496xx	MSRPC	Servicios RPC abiertos permiten enumeración e interacción con componentes internos (DCOM, spooler).	CVE-2021-1675	Restringir acceso a puertos, parchear sistema, aplicar segmentación.
Bajo	139	NetBIOS	Puerto 139 abierto puede permitir enumeración de usuarios, equipos y recursos en red local.		Deshabilitar si no se utiliza. Filtrar tráfico interno.
Bajo	80	HTTP (IIS 10.0)	HTTP activo. Si se permiten métodos como TRACE o versiones inseguras, puede habilitar vectores como XST.	CVE-2004-2320	

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 445 ■ Puerto 21 ■ Puerto 3389 ■ Puerto 5800/5900 ■ Puerto 135/496xx ■ Puerto 80 ■ Puerto 139

RECOMENDACIONES

- **Recomendaciones generales para la máquina Windows 10 auditada**
 - **Actualizar o deshabilitar el servicio FTP (FileZilla)** si no es necesario, o configurar autenticación segura y cifrado (FTPS).
 - **Aplicar todos los parches de seguridad acumulativos de Windows 10**, especialmente relacionados con SMBv2 y RDP.
 - **Restringir el acceso remoto al servicio RDP (puerto 3389)** mediante firewall, listas blancas de IPs y activación de NLA.
 - **Configurar o deshabilitar el servicio VNC (puertos 5800/5900)** si no se utiliza, y aplicar autenticación fuerte y cifrado si se mantiene.
 - **Cerrar puertos MSRPC (135 y 496xx)** si no se requieren. Limitar su uso a entornos internos y con privilegios mínimos.
 - **Deshabilitar NetBIOS si no es imprescindible**. En caso contrario, filtrar el acceso solo para redes internas autorizadas.
 - **Auditar la configuración del servidor web IIS (puerto 80)**. Desactivar métodos inseguros como TRACE y añadir cabeceras de seguridad.
 - **Realizar un seguimiento continuo del sistema** mediante soluciones EDR o SIEM, especialmente si expone servicios remotos.

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

EVIDENCIA N° 1 – FTP (FileZilla 0.9.60 beta)

- **Puerto: 21**
- **Nivel de Riesgo: Crítico**
- **Recomendación:**
 - Deshabilitar SMBv1, aplicar el parche de seguridad MS17-010, actualizar el sistema y restringir el acceso a SMB desde redes externas.
- **Descripción:**
 - Se observa el servicio FTP activo (FileZilla Server 0.9.60 beta). Las versiones beta suelen tener vulnerabilidades sin parches estables. Si se permite autenticación débil o anónima, puede facilitar accesos no autorizados o fuga de información.

```
Connected to 192.168.88.141.  
220-FileZilla Server 0.9.60 beta  
220-written by Tim Kosse (tim.kosse@filezilla-project.org)  
220 Please visit https://filezilla-project.org/  
Name (192.168.88.141:kali):
```

EVIDENCIA N° 2 – SMBv1 habilitado

- Puerto: 445
- Nivel de Riesgo: Crítico
- Recomendación:
 - Aplicar parches, deshabilitar SMBv1, restringir por firewall.
- Descripción:
 - Se ha verificado que el protocolo **SMBv1** está habilitado en la máquina objetivo 192.168.88.141. Esto supone una vulnerabilidad crítica ampliamente documentada, explotada por malware como WannaCry y EternalBlue.

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-16 08:18 EDT
Nmap scan report for 192.168.88.141
Host is up (0.00018s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:D0:95:A5 (VMware)

Host script results:
|_ smb-protocols:
|   dialects:
|       NT LM 0.12 (SMBv1) [dangerous, but default]
|       2:0:2
|       2:1:0
|       3:0:0
|       3:0:2
|_      3:1:1

Nmap done: 1 IP address (1 host up) scanned in 17.81 seconds
```

EVIDENCIA N° 3 – Servicio RDP expuesto

- **Puerto:** 3389
- **Nivel de Riesgo:** Alto
- **Recomendación:**
 - Habilitar NLA, restringir por IP, aplicar MFA y parches.
- **Descripción:**
 - El servicio de escritorio remoto (RDP) está disponible sin información de protección adicional (como NLA). Esto puede ser explotado mediante fuerza bruta, BlueKeep u otras técnicas de acceso remoto.

```
Host is up (0.00023s latency).  
  
PORT      STATE SERVICE  
3389/tcp  open  ms-wbt-server  
| rdp-ntlm-info:  
|   Target_Name: TSS  
|   NetBIOS_Domain_Name: TSS  
|   NetBIOS_Computer_Name: PC-POCEZ  
|   DNS_Domain_Name: TSS.local  
|   DNS_Computer_Name: PC-pocetz.TSS.local  
|   DNS_Tree_Name: TSS.local  
|   Product_Version: 10.0.18362  
|_ System_Time: 2025-07-17T18:04:41+00:00  
MAC Address: 00:0C:29:D0:95:A5 (VMware)
```

EVIDENCIA N° 4 – VNC activo (TightVNC)

- **Puerto:** 5800/5900
- **Nivel de Riesgo:** Alto
- **Recomendación:**
 - Habilitar autenticación fuerte, cifrado o restringir uso de VNC.
- **Descripción:**
 - El escaneo revela un servidor VNC (TightVNC) accesible públicamente. Este tipo de servicio no usa cifrado por defecto y puede ser comprometido si no tiene autenticación fuerte.

```
Connected to RFB server, using protocol version 3.8  
Enabling TightVNC protocol extensions  
Performing standard VNC authentication
```


EVIDENCIA N° 5 – MSRPC abierto

- Puerto: 135,496xx
- Nivel de Riesgo: Medio
- Recomendación:
 - Restringir acceso a puertos, parchear sistema, aplicar segmentación.
- Descripción:
 - Múltiples puertos asociados a Microsoft RPC están abiertos. Esto permite enumerar servicios internos y puede facilitar ataques como PrintNightmare si no está actualizado.

```
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||64892|)
150 Opening data channel for directory listing of "/"
drwxr-xr-x 1 ftp ftp          0 Mar 14 2021 $Recycle.Bin
drwxr-xr-x 1 ftp ftp          0 Jun 09 2025 $WINDOWS.BT
drwxr-xr-x 1 ftp ftp          0 Jun 09 2025 $WinREAgent
drwxr-xr-x 1 ftp ftp          0 Jan 05 2021 aeb996daea86d7b5f4e00e23226ee5
drwxr-xr-x 1 ftp ftp          0 Apr 30 2020 Archivos de programa
-r--r--r-- 1 ftp ftp    395268 Jul 10 2015 bootmgr
-r--r--r-- 1 ftp ftp          1 Jul 10 2015 BOOTNXT
drwxr-xr-x 1 ftp ftp          0 Mar 11 2021 Dev-Cpp
drwxr-xr-x 1 ftp ftp          0 Jul 10 2015 Documents and Settings
-r--r--r-- 1 ftp ftp    198670 Jan 12 2021 gpresult.html
drwxr-xr-x 1 ftp ftp          0 Jan 12 2021 inetpub
-r--r--r-- 1 ftp ftp    1006632960 Jul 16 14:02 pagefile.sys
drwxr-xr-x 1 ftp ftp          0 Mar 11 2021 PerfLogs
drwxr-xr-x 1 ftp ftp          0 Jul 16 14:02 Program Files
drwxr-xr-x 1 ftp ftp          0 Mar 23 2021 Program Files (x86)
drwxr-xr-x 1 ftp ftp          0 Mar 14 2021 ProgramData
drwxr-xr-x 1 ftp ftp          0 Apr 30 2020 Python27
drwxr-xr-x 1 ftp ftp          0 Jun 09 2025 Recovery
-r--r--r-- 1 ftp ftp    268435456 Jul 16 14:02 swapfile.sys
drwxr-xr-x 1 ftp ftp          0 Jan 12 2021 System Volume Information
drwxr-xr-x 1 ftp ftp          0 Mar 14 2021 Users
```

EVIDENCIA N° 6 – NetBIOS expuesto

- **Puerto: 139**
- **Nivel de Riesgo: Bajo**
- **Recomendación:**
 - Deshabilitar si no se utiliza. Filtrar tráfico interno.
- **Descripción:**
 - El puerto 139 permite comunicación NetBIOS, lo que facilita la enumeración de recursos compartidos y usuarios del sistema. Es un vector común de reconocimiento en ataques internos.

```
( Target Information )
Target ..... 192.168.88.141
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.88.141 )

[+] Got domain/workgroup name: TSS

( Nbtstat Information for 192.168.88.141 )

Looking up status of 192.168.88.141
TSS <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
PC-POCEZ <00> - M <ACTIVE> Workstation Service
PC-POCEZ <20> - M <ACTIVE> File Server Service
TSS <1e> - <GROUP> M <ACTIVE> Browser Service Elections
TSS <1d> - M <ACTIVE> Master Browser
.._MSBROWSE_. <01> - <GROUP> M <ACTIVE> Master Browser

MAC Address = 00-0C-29-D0-95-A5
```

EVIDENCIA N° 7 – HTTP activo (IIS 10.0)

- **Puerto: 80**
- **Nivel de Riesgo: Bajo**
- **Descripción:**
 - El servidor web IIS 10.0 está activo. Si no se protegen los métodos HTTP o se deshabilita TRACE, podría facilitar ataques como XST o exposición innecesaria de información..

```
+ Target IP:      192.168.88.141
+ Target Hostname: 192.168.88.141
+ Target Port:    80
+ Start Time:     2025-07-17 14:28:54 (GMT-4)

+ Server: Microsoft-IIS/10.0
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ 8102 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time:       2025-07-17 14:29:05 (GMT-4) (11 seconds)

+ 1 host(s) tested
```

CONCLUSIÓN

- Durante la auditoría realizada al sistema Windows 10 , se detectó una exposición significativa de servicios críticos como FTP, SMBv2, RDP y VNC. Algunos de estos presentan vulnerabilidades conocidas o configuraciones inseguras que podrían ser explotadas para comprometer la confidencialidad, integridad o disponibilidad del sistema.
- También se identificaron servicios internos (MSRPC, NetBIOS) que, aunque no representan un riesgo crítico por sí solos, amplían la superficie de ataque si no se segmentan y protegen adecuadamente.
- Se recomienda implementar las medidas correctivas indicadas, priorizar la actualización del sistema y realizar una revisión periódica de la configuración de los servicios expuestos. La reducción de la superficie de ataque es esencial para mantener una postura de seguridad robusta frente a amenazas actuales.

INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha: 16/07/2025
- Entorno: Windows Server 2019

○ IP-> 192.168.88.143

OBJETIVO Y ALCANCE

- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows Server 2019** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- El análisis de seguridad realizado sobre el sistema **Windows Server 2019** ha revelado la exposición de varios servicios críticos y una configuración que incrementa la superficie de ataque del sistema. Entre los hallazgos más relevantes se encuentran:
- El servicio **SMBv2 activo en el puerto 445**, históricamente vinculado a vulnerabilidades graves como EternalBlue.
- **Servicios RPC abiertos en múltiples puertos**, que pueden facilitar la enumeración de información sensible o ser aprovechados como vector de movimiento lateral.
- La **exposición del protocolo RDP**, que podría permitir intentos de acceso remoto no autorizado si no está protegido adecuadamente.
- La **presencia de NetBIOS**, lo que habilita mecanismos de descubrimiento e identificación de recursos compartidos.
- Aunque se trata de un sistema moderno, algunas configuraciones por defecto, combinadas con la exposición de servicios ampliamente atacados, elevan el riesgo general del entorno si no se aplican controles adecuados.

CLASIFICACIÓN DE VULNERABILIDADES

- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.

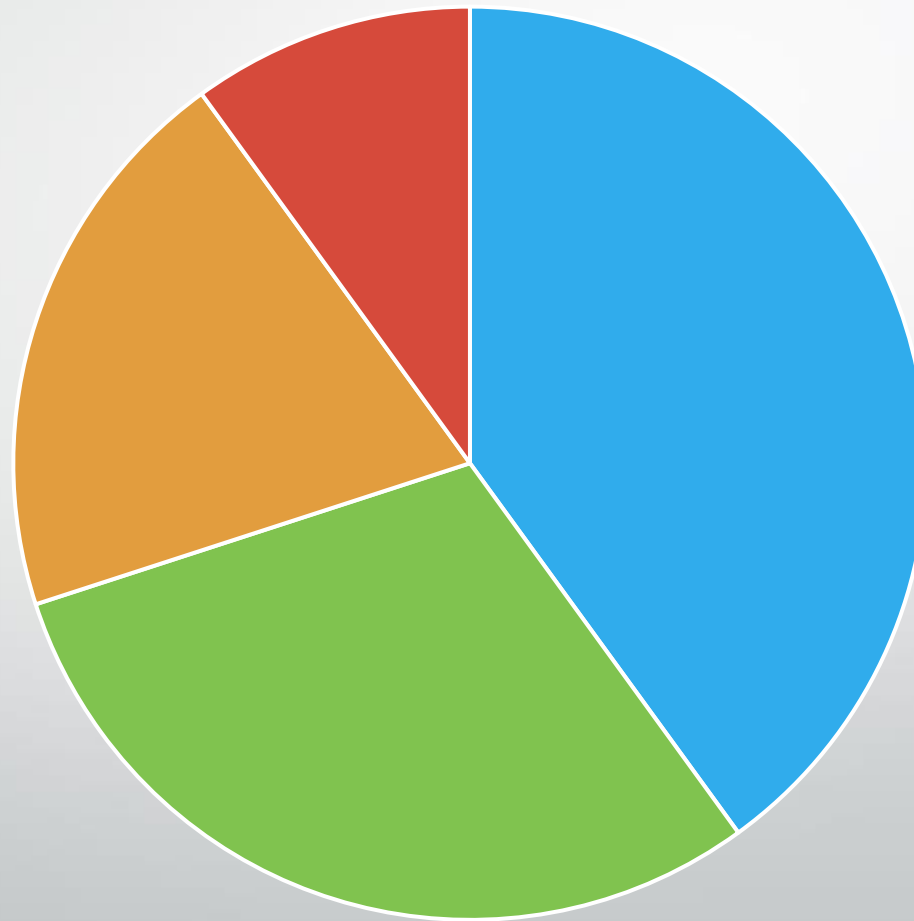


TABLA DE VULNERABILIDADES

Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	22	SSH	Permite el acceso remoto a la línea de comandos del sistema. La vulnerabilidad más crítica aquí es la existencia de credenciales débiles .	CVE-2018-15473.	-Fortalecer contraseñas. -Autenticación por claves SSH. -Autenticación Multifactor. -Limitar acceso
Alto	445	SMB	Se utiliza para la compartición de archivos, impresoras y para la comunicación entre procesos en sistemas Windows	-CVE-2017-0144 -CVE-2020-0796	-Deshabilitar SMBv1 -Firmado SMB -Permisos estrictos. -Firewall. -Actualizaciones y parches
Medio	135	MSRPC	Permite comunicación entre procesos en sistemas Windows.es un vector común para la enumeración de información del sistema	CVE-2021-1675	-Segmentar redes. -Actualizaciones y parches. Principio de mínimo privilegio
Bajo	80	Microsoft IIS httpd 10	permiten robar cookies o información de cabeceras HTTP si el navegador y las condiciones de red lo permiten	CVE-2004-2320	Deshabilitar el método TRACE en la configuración del servidor web. Verificar los métodos habilitados y restringir únicamente a los necesarios

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 22 ■ Puerto 445 ■ Puerto 135 ■ Puerto 80

RECOMENDACIONES

- **Aplicar los parches de seguridad críticos del sistema operativo**, especialmente aquellos relacionados con los servicios SMB, RDP y MSRPC.
- **Restringir el acceso a puertos críticos** (445, 3389, 135, etc.) mediante firewall y segmentación de red, limitando su visibilidad solo a redes internas confiables.
- **Habilitar la Autenticación a Nivel de Red (NLA)** en RDP y complementar con mecanismos de doble factor (MFA) siempre que sea posible.
- **Deshabilitar servicios innecesarios o inseguros**, como NetBIOS, si no son requeridos por el entorno operativo.
- **Fortalecer las políticas de contraseñas y autenticación**, especialmente en cuentas de administración o servicio.
- **Monitorear la actividad de red y del sistema en tiempo real**, implementando soluciones de detección de amenazas (EDR/SIEM).
- **Auditar periódicamente la exposición de servicios y configuraciones**, especialmente tras actualizaciones, nuevos despliegues o cambios en la red.
- **Formar y sensibilizar al equipo técnico** sobre buenas prácticas de ciberseguridad y gestión de servidores Windows.

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

EVIDENCIA N° 1 – SSH

- **Puerto:** 22
- **Nivel de riesgo:** Crítico
- **Recomendación:**
 - Fortalecer contraseñas.
 - Autenticación por claves SSH.
 - Autenticación Multifactor.
 - Limitar acceso
- **Descripción:**
 - El servicio SSH permite el acceso remoto al sistema operativo a través de una terminal segura. En este caso, el servicio OpenSSH está activo y expuesto públicamente, y se ha podido acceder exitosamente usando credenciales válidas del usuario administrador del dominio . Esto representa un riesgo crítico, ya que otorga control total del sistema a través de un canal cifrado.

Password for [TSS\administrador]:

Sharename	Type	Comment
ADMIN\$	Disk	Admin remota
C\$	Disk	Recurso predeterminado
IPC\$	IPC	IPC remota
NETLOGON	Disk	Recurso compartido del servidor de inicio de sesión
Recursos empresa	Disk	
SYSVOL	Disk	Recurso compartido del servidor de inicio de sesión

Reconnecting with SMB1 for workgroup listing.

EVIDENCIA N° 2 – Servicio SMB activo

- **Puerto:** 445
- **Nivel de riesgo:** Alto
- **Recomendación:**
 - Deshabilitar SMBv1
 - Firmado SMB
 - Permisos estrictos.
 - Firewall.
 - Actualizaciones y parches
- **Descripción:**
 - El puerto 445 se encuentra abierto con el servicio Microsoft SMB activo. Este protocolo ha sido históricamente vulnerable a ejecución remota de código si no está parcheado, como es el caso de CVE-2009-3103.

Password for [TSS\administrador]:

Sharename	Type	Comment
ADMIN\$	Disk	Admin remota
C\$	Disk	Recurso predeterminado
IPC\$	IPC	IPC remota
NETLOGON	Disk	Recurso compartido del servidor de inicio de sesión
Recursos empresa	Disk	
SYSVOL	Disk	Recurso compartido del servidor de inicio de sesión

Reconnecting with SMB1 for workgroup listing.

EVIDENCIA N° 3 – Servicio MSRPC expuesto

- **Puerto:** 135
- **Nivel de riesgo:** Medio
- **Recomendación:**
 - Segmentar redes.
 - Actualizaciones y parches.
 - Principio de mínimo privilegio
- **Descripción:**
 - El puerto 135 está abierto con el servicio MSRPC activo. Este puerto permite llamadas a procedimientos remotos y puede servir como puerta de entrada para ataques como PrintNightmare (CVE-2021-1675) si no se encuentra correctamente parchado.

```
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.88.143 ) =====
[+] Got domain/workgroup name: TSS

===== ( Nbtstat Information for 192.168.88.143 ) =====
Looking up status of 192.168.88.143
TSS <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
CONTROLADORDOM <00> - <GROUP> M <ACTIVE> Workstation Service
TSS <1c> - <GROUP> M <ACTIVE> Domain Controllers
CONTROLADORDOM <20> - <GROUP> M <ACTIVE> File Server Service
TSS <1b> - <GROUP> M <ACTIVE> Domain Master Browser

MAC Address = 00-0C-29-F4-AD-AE

===== ( Session Check on 192.168.88.143 ) =====
[+] Server 192.168.88.143 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.88.143 ) =====
Domain Name: TSS
Domain Sid: S-1-5-21-765635370-698130357-804349127
```

EVIDENCIA N° 4 – HTTP TRACE Habilitado

- **Puerto:** 80
- **Nivel de riesgo:** Bajo
- **Recomendación:**
 - Deshabilitar el método TRACE en la configuración del servidor web. Verificar los métodos habilitados y restringir únicamente a los necesarios
- **Descripción:**
 - Se observa que el servidor web IIS tiene habilitado el método HTTP TRACE. Esta configuración puede ser aprovechada para ataques XST (Cross Site Tracing). Está clasificada como una vulnerabilidad de riesgo bajo que debe corregirse.

```
80/tcp    open  http           Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
|_http-methods:
|_ Potentially risky methods: TRACE
```


CONCLUSIÓN

- La auditoría realizada sobre el sistema **Windows Server 2019** ha permitido identificar una serie de servicios expuestos que, en conjunto, incrementan la superficie de ataque y podrían comprometer la seguridad del entorno si no se gestionan adecuadamente.
- La presencia de **servicios críticos como SMBv2, RDP y MSRPC** abiertos sin restricciones, así como protocolos como **NetBIOS**, representa un riesgo significativo, especialmente si no se acompañan de medidas de control como segmentación de red, autenticación reforzada y gestión de parches.
- El sistema presenta debilidades técnicas que deben ser corregidas para prevenir accesos no autorizados, fugas de información o escaladas de privilegios.
- Se recomienda aplicar una estrategia de **reducción de superficie de ataque**, junto con **parcheo proactivo, endurecimiento de configuraciones** y la implementación de **controles preventivos** como MFA, monitoreo de logs y listas de control de acceso. Con estas medidas, la organización podrá fortalecer su postura frente a amenazas internas y externas.